



Protocolos de Comunicação Seguros

Segurança em Redes e Sistemas Informáticos

CTeSP em Redes e Sistemas Informáticos

Escola Superior de Tecnologia e Gestão de Águeda

Universidade de Aveiro

2025-26

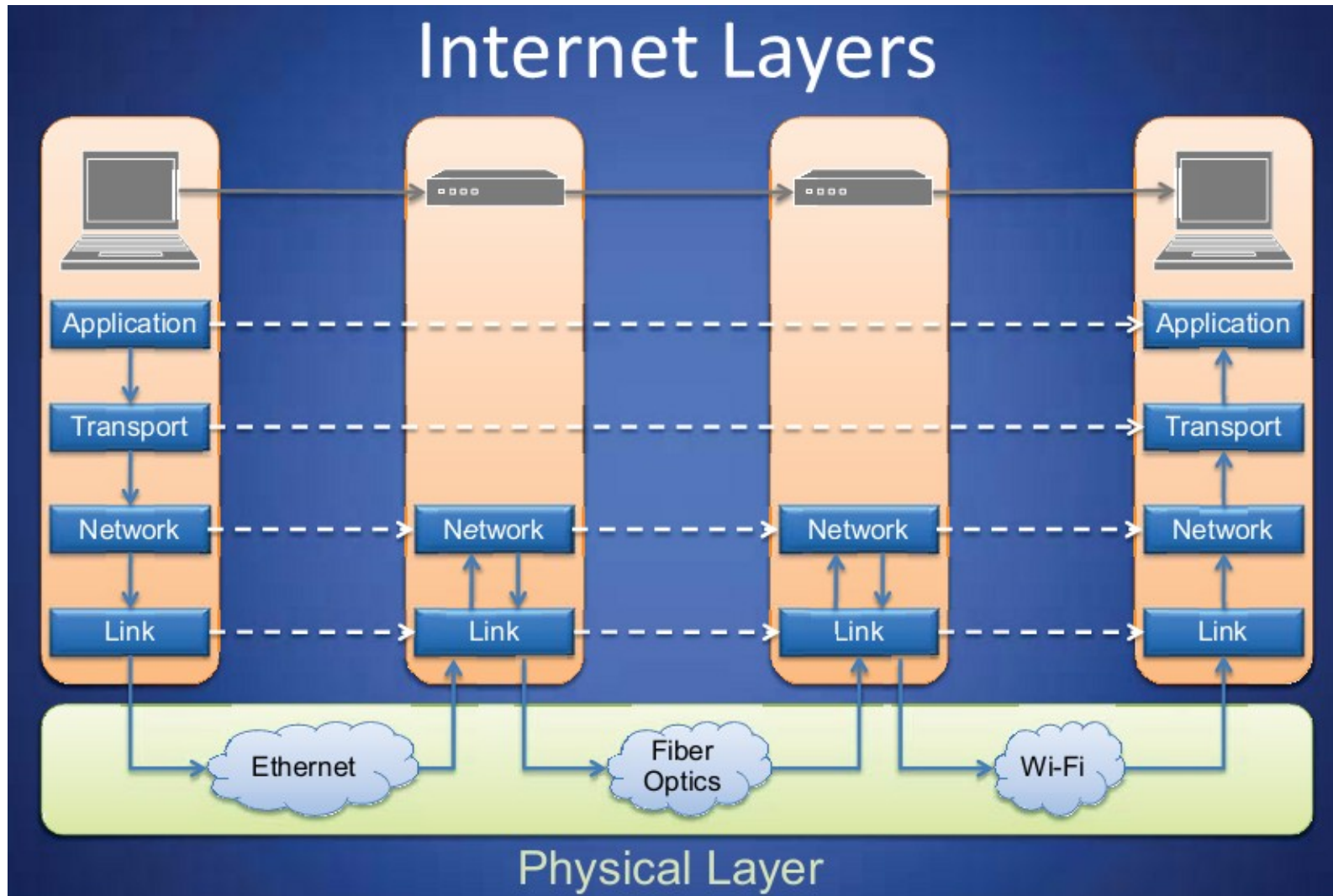


Tópicos

- SSH (Secure shell)
- SSL/TLS (Secure Socket Layer / Transport Layer Security)
 - HTTPS (HTTP over SSL/TLS)
- Virtual Private Networks (VPN)



Pilha protocolar TCP/IP





Protocolos de segurança:

Localização na pilha protocolar TCP/IP

Pilha TCP/IP	Aproximação	Protocolos
Aplicação	Cifra entre extremos (end-to-end encryption)	HTTPS, SSH, Kerberos
Transporte		SSL/TLS
Internet		IPSec
Acesso à Rede	Cifra por troços (link encryption)	Ligações sem fios, PPP



SSH (Secure Shell)



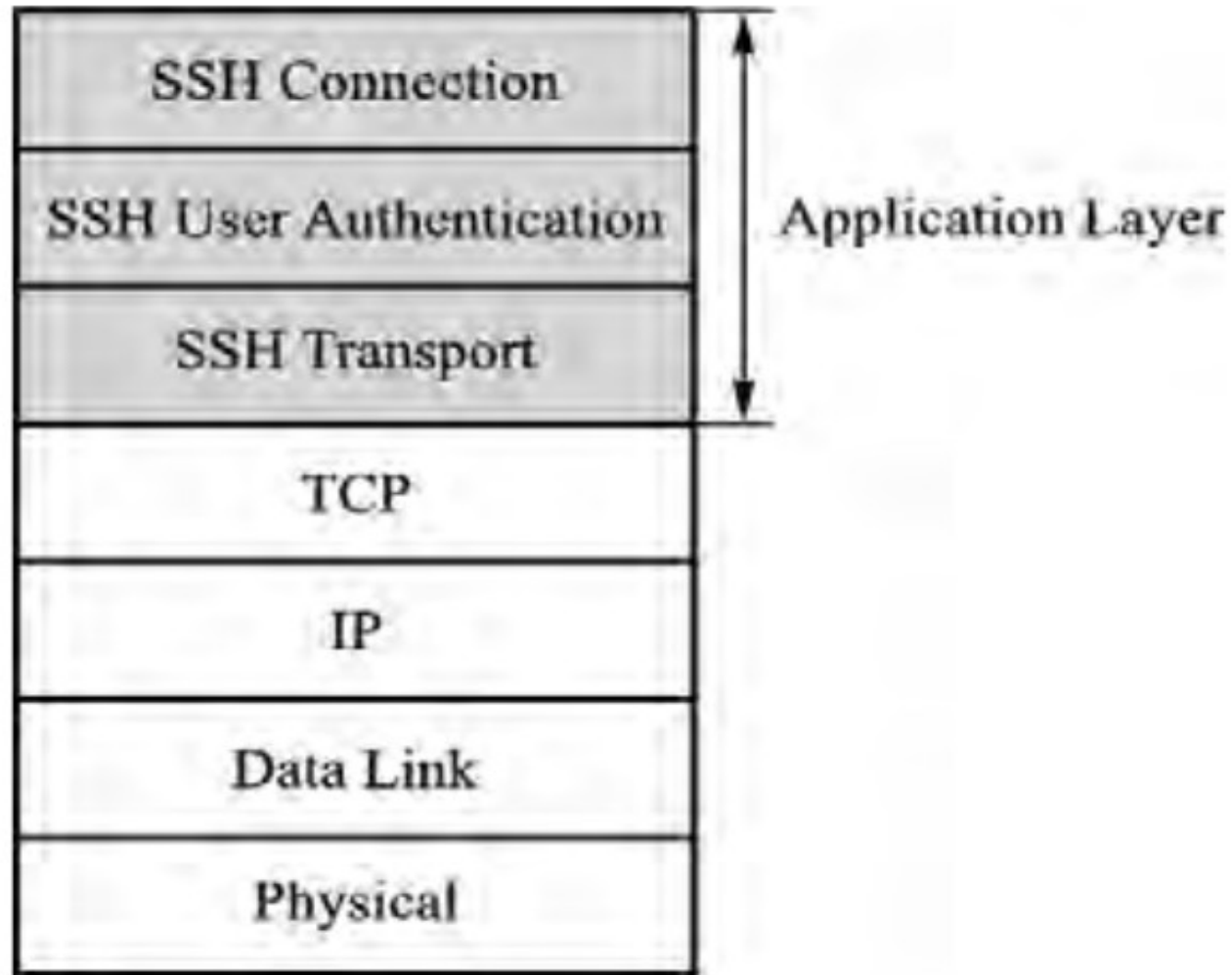


SSH – Secure Shell

- Protocolo de segurança para logins remotos
 - Substituir Telnet, rlogin e rsh que transmitem dados sem nenhuma proteção criptográfica
 - Inclui SFTP (FTP seguro) e SCP (cópia de ficheiros segura)
- Serviços fornecidos:
 - Confidencialidade dos dados
 - Integridade dos dados
 - Autenticação dos interlocutores
- Servidor SSH por omissão escuta no porto 22 do TCP



SSH na pilha protocolar





SSH: Protocolos

- SSH Transport
 - Responsável pela autenticação do servidor, pela troca de chaves iniciais, e pela inicialização dos algoritmos de cifra e compressão
 - Garante que ligações subsequentes são feitas com o mesmo servidor
 - Os pacotes trocados são cifrados usando um algoritmo de cifra simétrica
- SSH User Authentication
 - Autentica o utilizador perante o servidor, através de uma password ou através de criptografia assimétrica
- SSH Connection
 - Estabelecimento de múltiplos canais, para diferentes aplicações, sobre uma mesma ligação.



SSH: Primeira ligação do cliente (autenticação do servidor)

- Através do comando **ssh username@remotehost**

```
The authenticity of host '111.111.11.111 (111.111.11.111)' can't be established.  
ECDSA key fingerprint is fd:fd:d4:f9:77:fe:73:84:e1:55:00:ad:d6:6d:22:fe.  
Are you sure you want to continue connecting (yes/no)? yes
```

- O servidor identifica-se apresentando o fingerprint da sua chave pública, que deve ser do conhecimento do utilizador.
- É da responsabilidade do utilizador dizer se reconhece ou não o fingerprint do servidor como legítimo e continuar a ligação
- A não ser que haja uma alteração de chave no servidor, nas ligações subsequentes não é mostrado o fingerprint porque ele é guardado e validado pelo cliente.

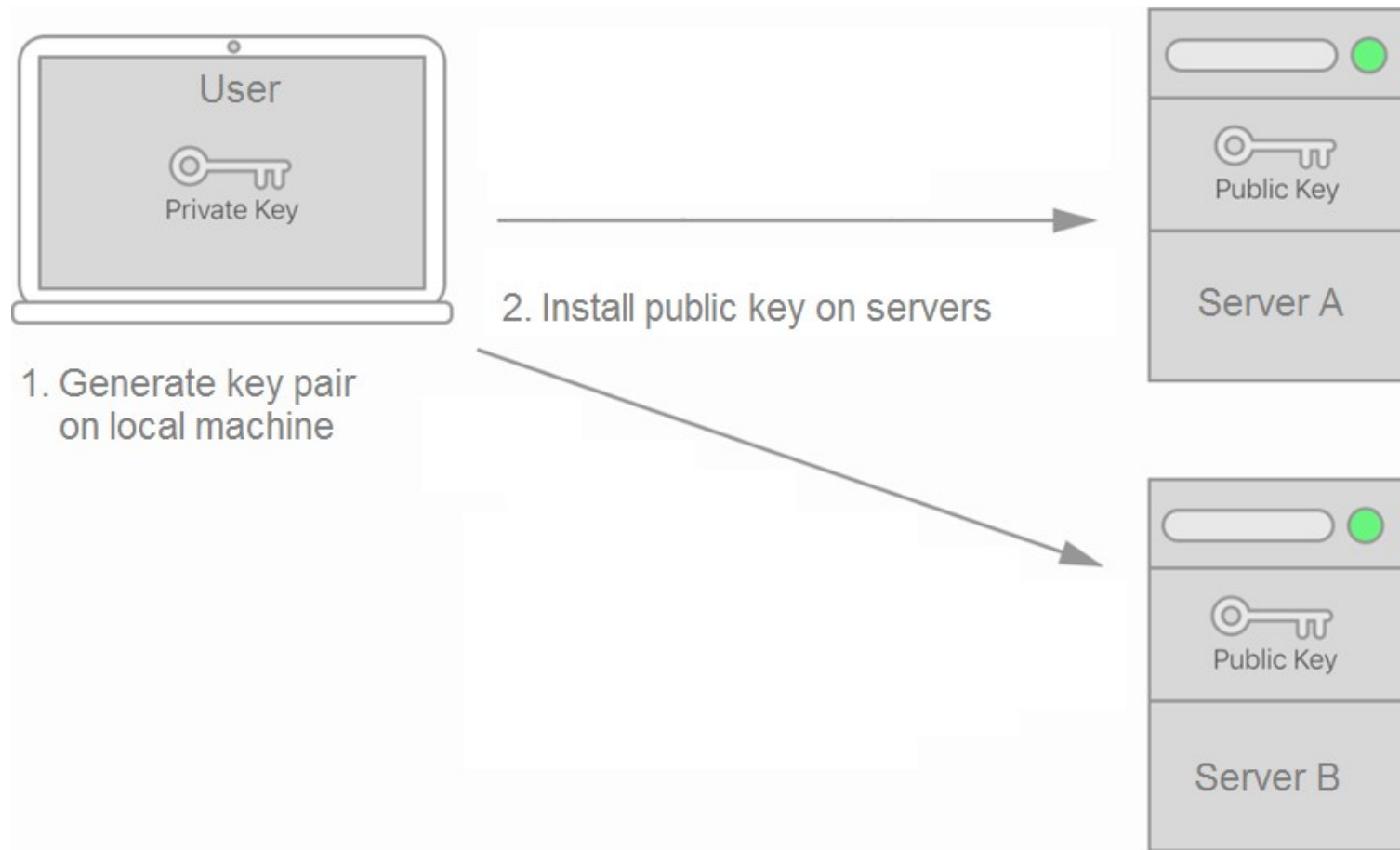


Autenticação do utilizador

- Pode ser feita de várias formas:
 - Username / password
 - Par de chaves assimétricas
 - One-time password
 - <https://www.digitalocean.com/community/tutorials/how-to-set-up-multi-factor-authentication-for-ssh-on-ubuntu-16-04>

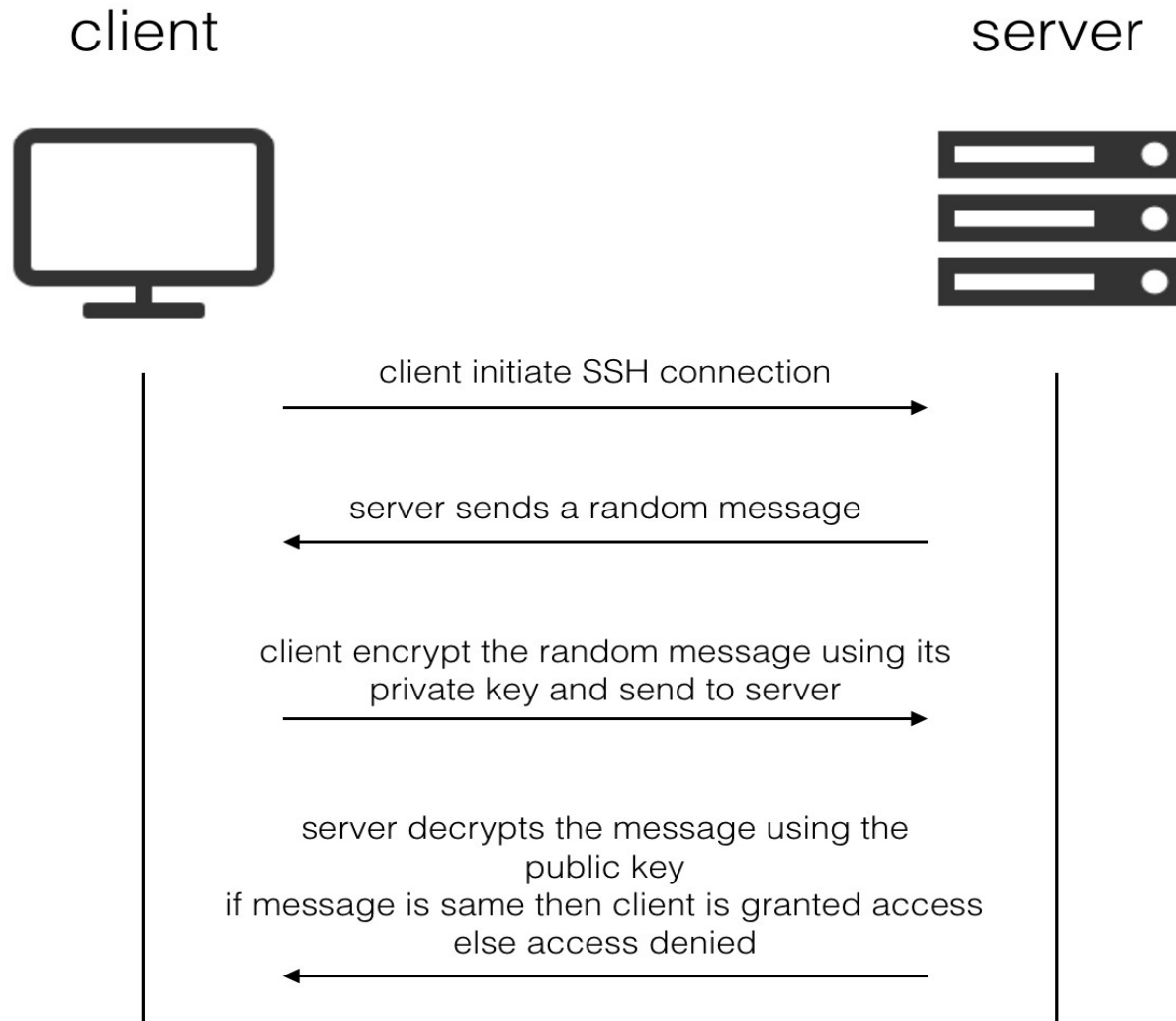


SSH: Par de chaves do utilizador





SSH key based user authentication





HTTPS (HTTP over SSL/TLS)



Http



Https



SSL / TLS - Secure Socket Layer / Transport Layer Security

- Protocolos criptográficos que permitem comunicação segura sobre TCP/IP (inseguro)
 - SSL – Secure Sockets Layer
 - Desenvolvido pela Netscape em 1994 para proteger transações eletrónicas na Web
 - Não é recomendada a sua utilização
 - TLS – Transport Layer Security
 - Sucessor, criado a partir do SSL v3.0
 - Definido por uma entidade normalizadora: IETF
 - São técnica e filosoficamente quase iguais, mas não são compatíveis.
 - O que levou à manutenção dos dois em muitas aplicações
 - Ambos os termos são comumente utilizados de forma indiferenciada
-



SSL/TLS: Modelo de Operação

- Modelo cliente-servidor
 - Tal como numa ligação TCP
- Clientes indicam:
 - Se é necessária autenticação do servidor
 - Quais os algoritmos que suporta (Cipher suites)
 - O servidor escolhe
- Gestão de sessões seguras sobre TCP/IP
 - Inicialmente concebido para tráfego HTTP
 - HTTPS: HyperText Transfer Protocol Secure (HTTP over SSL)
 - Atualmente usado também para outros tráfegos
 - IMAPS, SMTPS, ...



SSL/TLS: Serviços de Segurança Disponibilizados

- Negociação de chaves
 - Suporta vários protocolos: O servidor escolhe de entre os propostos pelo cliente
 - Mais comum: RSA
 - Material para gerar chaves é enviado para o servidor, cifrado com chave pública deste
- Confidencialidade e integridade da comunicação
 - Cifra Simétrica e *Message Authentication Codes* (MAC)
- Autenticação de interlocutores
 - Através de certificados de chave pública



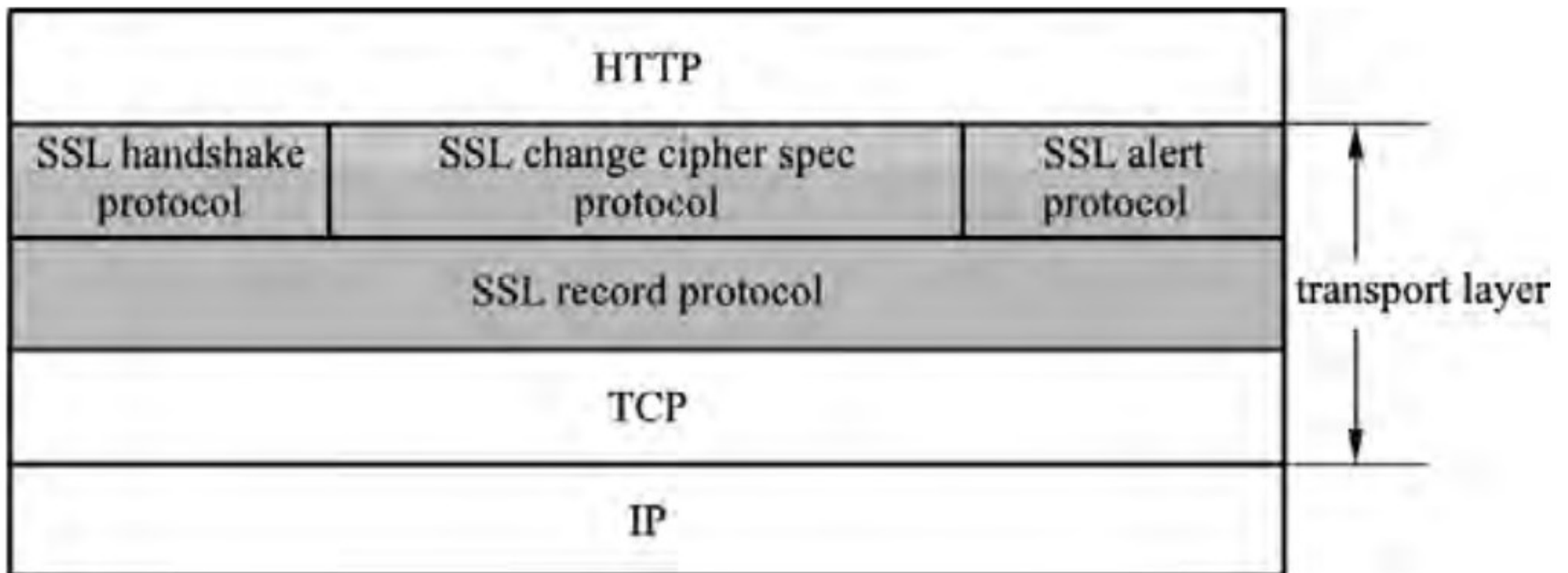
SSL/TLS: Utilização pelas aplicações

- Duas interfaces
 - A convencional, com o porto de transporte habitual
 - Uma sobre SSL, com um porto de transporte novo
- Obriga a alterações nas aplicações para gerir a camada SSL

Protocolos	Porto Normal	Porto TLS
HTTP	80	443
IMAP	143	993
POP3	110	995
SMTP	25	465
LDAP	389	636



SSL/TLS na pilha protocolar



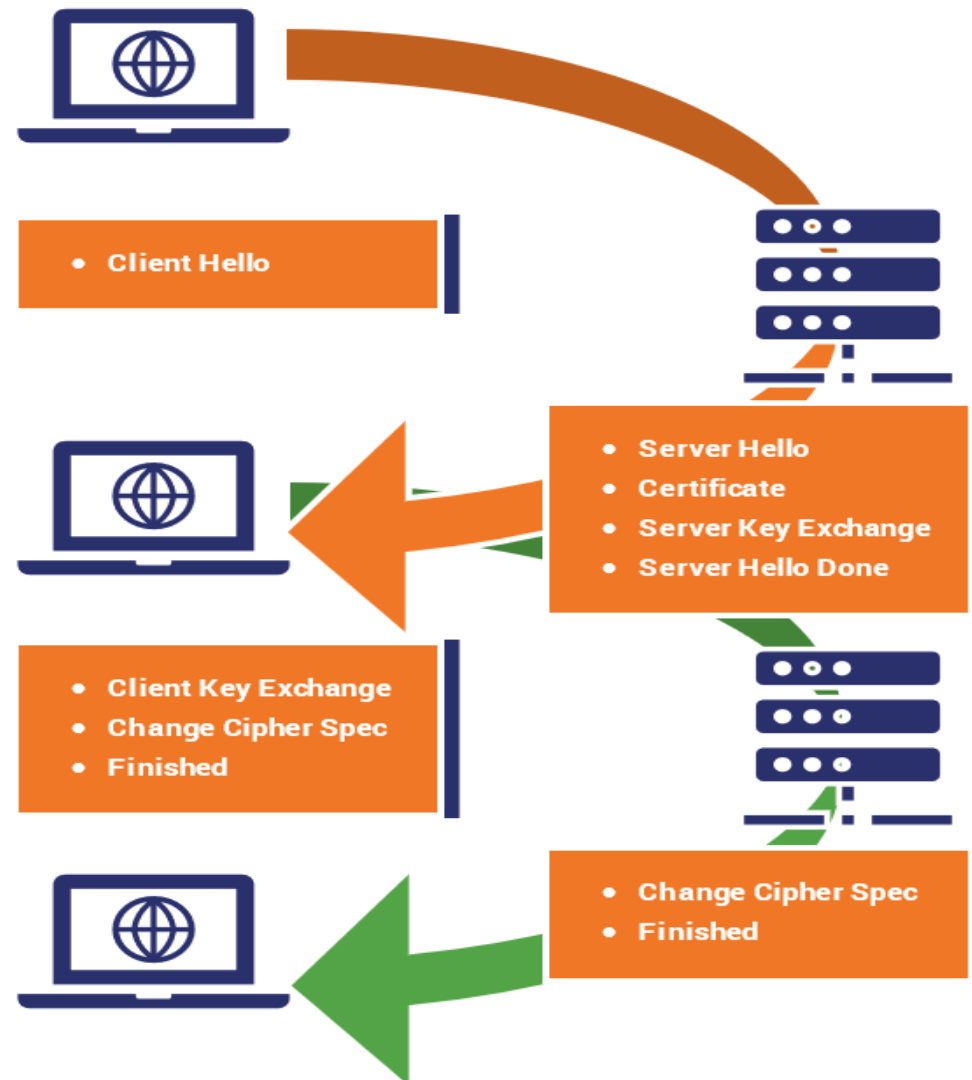


SSL/TLS: Handshake Protocol

- O Handshake protocol tem como objetivo:
 - Negociar cipher suites
 - Uma cipher suite é um conjunto de algoritmos para:
 - Negociação de chaves
 - Autenticação/Assinatura digital
 - Cifra de dados
 - Integridade (Message Authentication Code)
 - TLS 1.2 **TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256**
 - TLS 1.3 **TLS_AES_256_GCM_SHA384**
 - Autenticação dos interlocutores
 - Nenhuma autenticação
 - Autenticação apenas do servidor (mais comum) – Através de certificados digitais
 - Autenticação mútua, do servidor e do cliente – Através de certificados digitais
 - Negociar chaves simétricas de sessão
 - TLS 1.2: Depende da cipher suite selecionada: RSA ou DHE
 - TLS 1.3: apenas duas versões de ECDHE

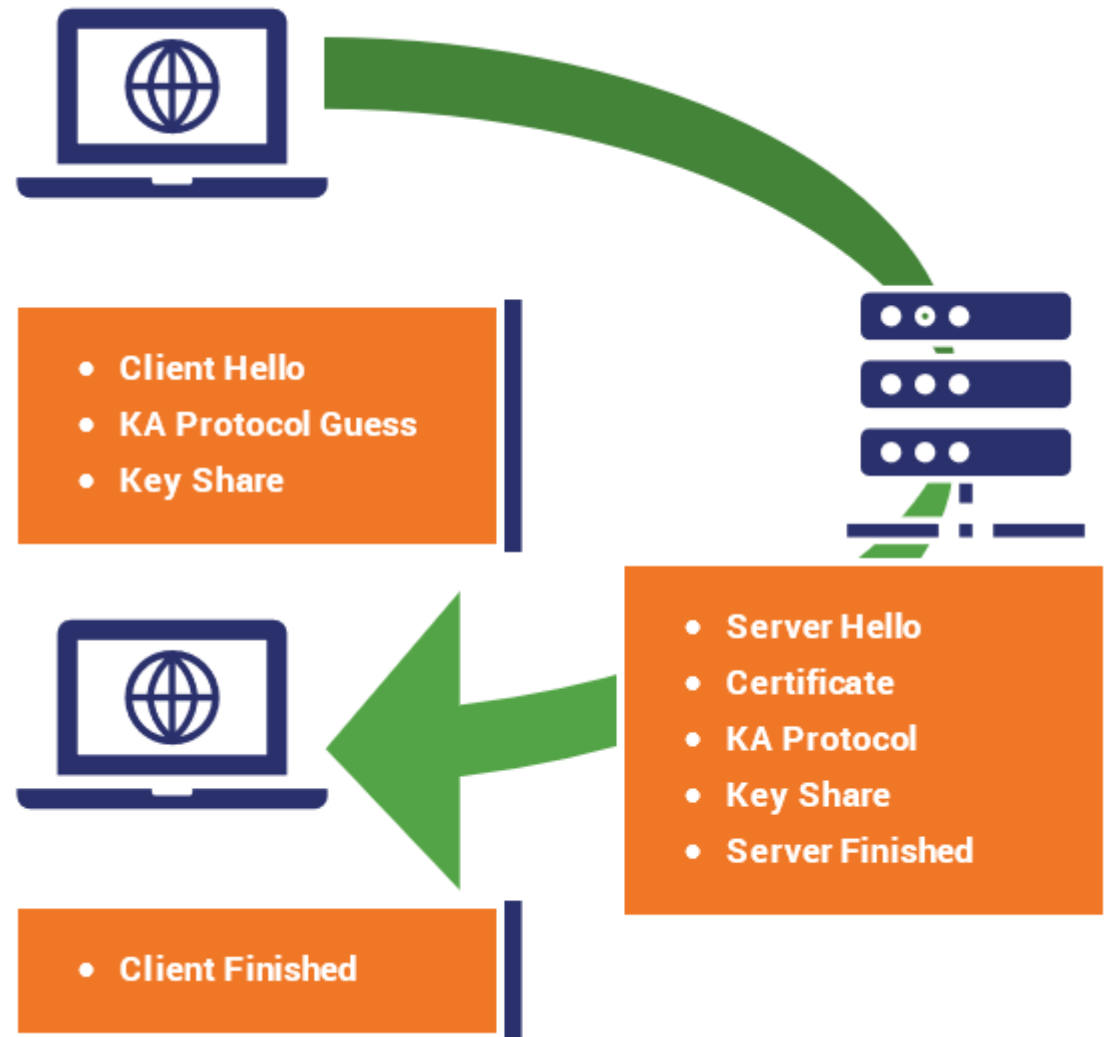


SSL/TLS: *Handshake Protocol (TLS 1.2)*





SSL/TLS: Handshake Protocol (TLS 1.3)



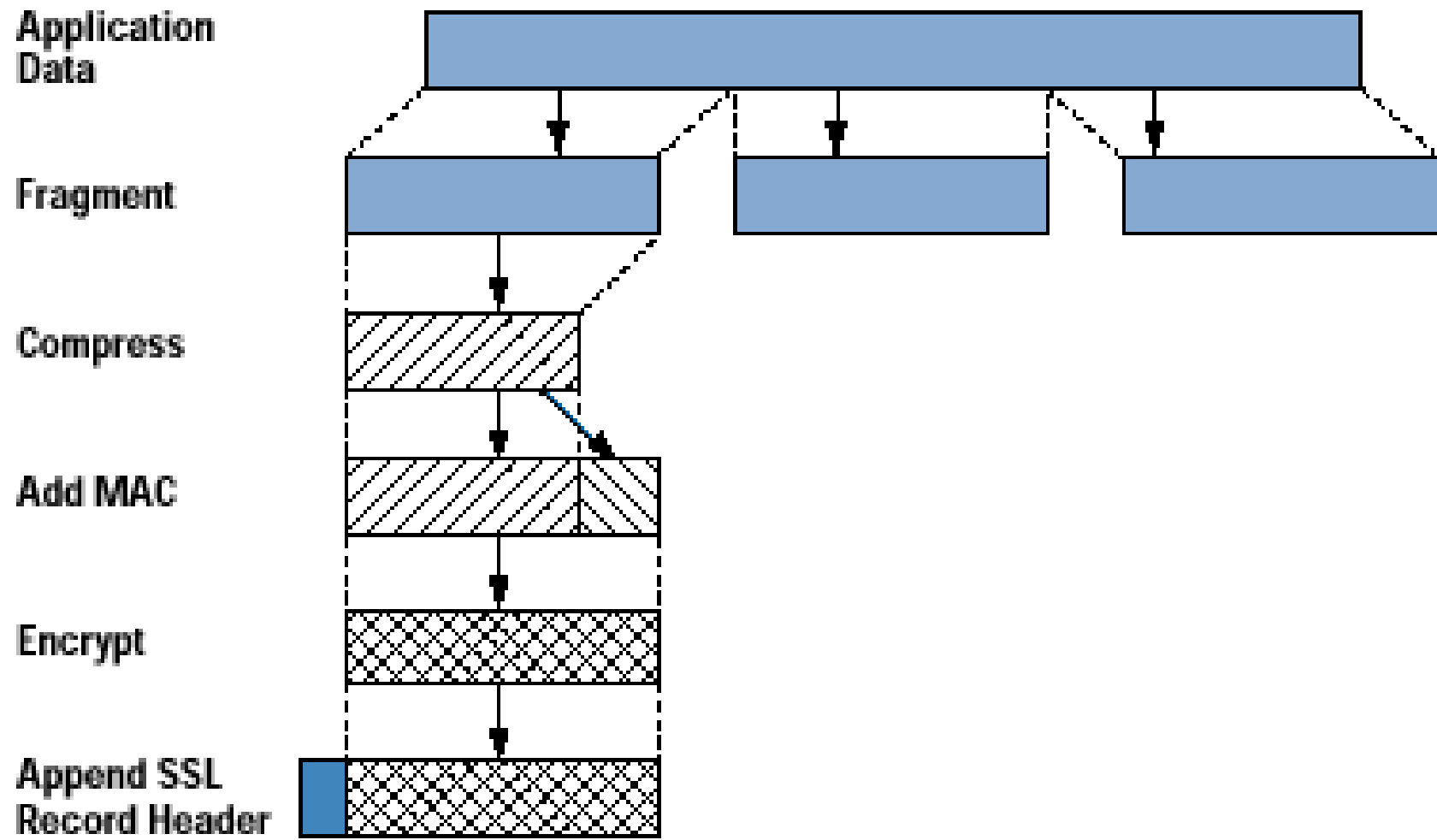


SSL/TLS: *Record Protocol*

- Gere o transporte seguro sobre um protocolo de transporte inseguro, o TCP.
- Fornece:
 - Confidencialidade:
 - cifra da mensagens usando chaves de sessão derivadas da chave mestra (cifra simétrica)
 - Controlo de integridade:
 - usando chaves de sessão, derivadas da chave mestra, para calcular um Message Authentication Code (MAC), que é incluído na mensagem



SSL/TLS: *Record Protocol*





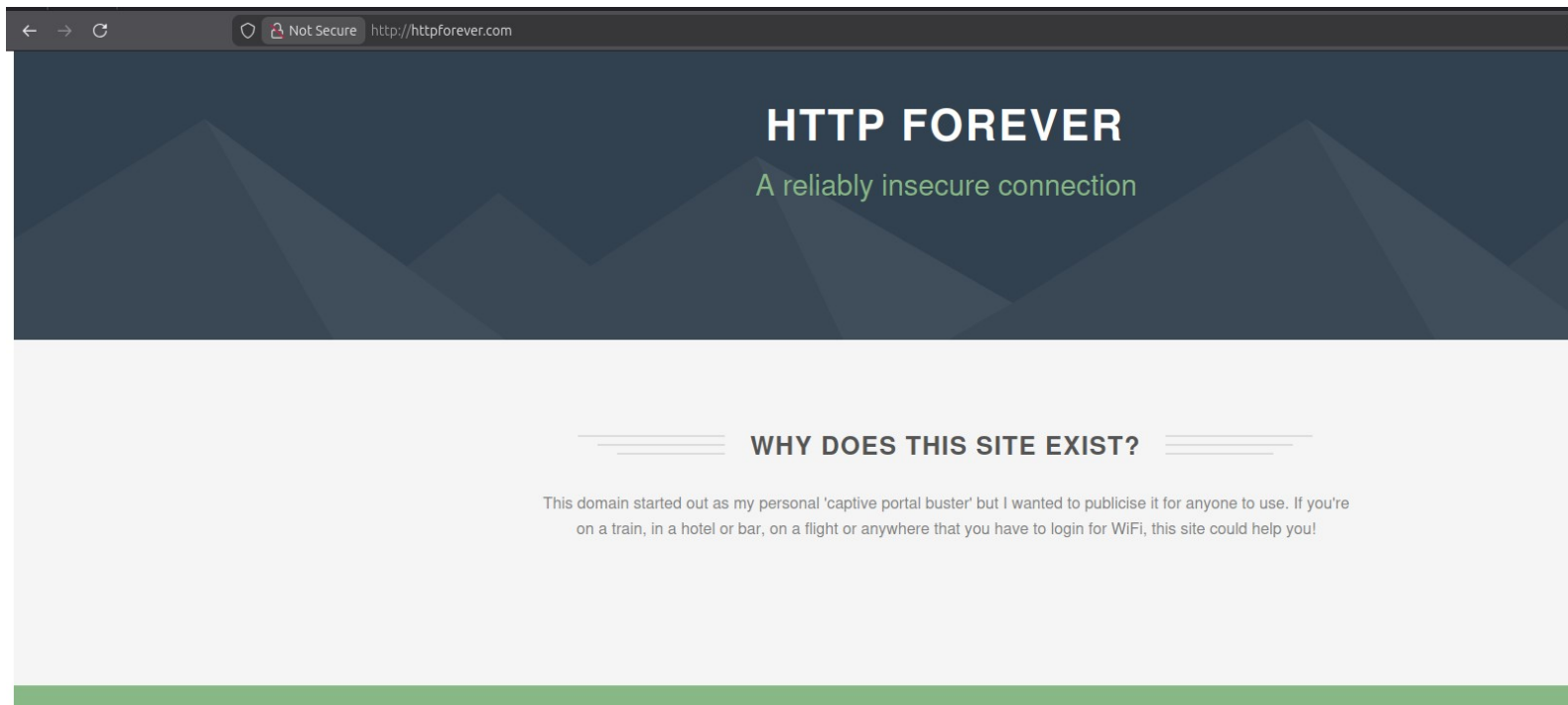
Navegação na Web: HTTP



http://info.cern.ch - home of the first website

From here you can:

- [Browse the first website](#)
- [Browse the first website using the line-mode browser simulator](#)
- [Learn about the birth of the web](#)
- [Learn about CERN, the physics laboratory where the web was born](#)





Navegação segura na Web: HTTPS





HTTPS: Exercício

- Inicie uma captura com o Wireshark sobre a Interface de rede do seu computador
- Aceda ao site da Câmara de Aveiro
 - www.cm-aveiro.pt
- Pare a captura e analise o tráfego HTTPS capturado.
 - Consegue identificar o tráfego TLS?
 - Qual a versão do TLS usada?
 - Qual a cipher suite utilizada na ligação (seleccionada pelo servidor)?
 - Consegue observar os certificados trocados entre o servidor e o seu browser?



Certificado apresentado por cm-aveiro.pt

Certificate

*.cm-aveiro.pt		GoGetSSL RSA DV CA	USERTrust RSA Certification Authority
Subject Name			
Common Name	*.cm-aveiro.pt		
Issuer Name			
Country	LV		
Locality	Riga		
Organisation	GoGetSSL		
Common Name	GoGetSSL RSA DV CA		
Validity			
Not Before	Mon, 16 May 2022 00:00:00 GMT		
Not After	Mon, 22 May 2023 23:59:59 GMT		
Subject Alt Names			
DNS Name	*.cm-aveiro.pt		
DNS Name	cm-aveiro.pt		
Public Key Info			
Algorithm	RSA		
Key Size	4096		
Exponent	65537		
Modulus	EA:EA:EC:8D:37:F0:5D:77:DE:C9:64:FB:DC:BE:68:E3:F0:D9:92:AB:7E:EC:4B:9...		
Miscellaneous			
Serial Number	2C:AC:F3:C6:8A:9E:8F:06:AB:38:9F:AD:57:13:C1:8C		
Signature Algorithm	SHA-256 with RSA Encryption		
Version	3		
Download	PEM (cert) PEM (chain)		



Falha na autenticação do servidor

The screenshot shows a Mozilla Firefox browser window with a warning message: "Warning: Potential Security Risk Ahead". The address bar shows the URL "https://www.cm-viana-castelo.pt" and the status "Not Secure". Below the browser window, the warning message is repeated: "Warning: Potential Security Risk Ahead". The text explains that Firefox detected a potential security threat and did not continue to the website because the certificate is not trusted as it is self-signed. The error code is "MOZILLA_PKIX_ERROR_SELF_SIGNED_CERT". There are two buttons: "Go Back (Recommended)" and "Advanced...". Below this, a detailed box shows the error message: "www.cm-viana-castelo.pt uses an invalid security certificate. The certificate is not trusted because it is self-signed. Error code: MOZILLA_PKIX_ERROR_SELF_SIGNED_CERT". There is a link "View Certificate" and two buttons at the bottom: "Go Back (Recommended)" and "Accept the Risk and Continue".

Warning: Potential Security Risk Ahead

Firefox detected a potential security threat and did not continue to **www.cm-viana-castelo.pt**. If you visit this site, attackers could try to steal information like your passwords, emails, or credit card details.

[Learn more...](#)

[Go Back \(Recommended\)](#) [Advanced...](#)

www.cm-viana-castelo.pt uses an invalid security certificate.

The certificate is not trusted because it is self-signed.

Error code: [MOZILLA_PKIX_ERROR_SELF_SIGNED_CERT](#)

[View Certificate](#)

[Go Back \(Recommended\)](#) [Accept the Risk and Continue](#)



Porquê a falha na autenticação?

Certificate for portal.cm-viana-castelo.pt — Mozilla Firefox

Warning: Potential Security ... Certificate for portal.cm-viana- ...

Firefox about:certificate?cert=MIIDUzCCARYgAwIBAgICGjMwDQYJKoZIhvcNAQ...

portal.cm-viana-castelo.pt

Subject Name

Country	--
State/Province/County	SomeState
Locality	SomeCity
Organisation	SomeOrganization
Organisational Unit	SomeOrganizationalUnit
Common Name	portal.cm-viana-castelo.pt
Email Address	root@portal.cm-viana-castelo.pt

Issuer Name

Country	--
State/Province/County	SomeState
Locality	SomeCity
Organisation	SomeOrganization
Organisational Unit	SomeOrganizationalUnit
Common Name	portal.cm-viana-castelo.pt
Email Address	root@portal.cm-viana-castelo.pt

Validity

Not Before	Thu, 15 Nov 2012 12:29:18 GMT
Not After	Fri, 15 Nov 2013 12:29:18 GMT



Verificação de Sites

- Online
 - <https://www.ssllabs.com/ssltest>
 - <https://webcheck.pt/pt/>
 - <https://www.hardenize.com/>
 - <https://www.immuniweb.com/>
- Linha de comando (Linux)
 - `testssl`



VPN – Virtual Private Network (Rede Privada Virtual)



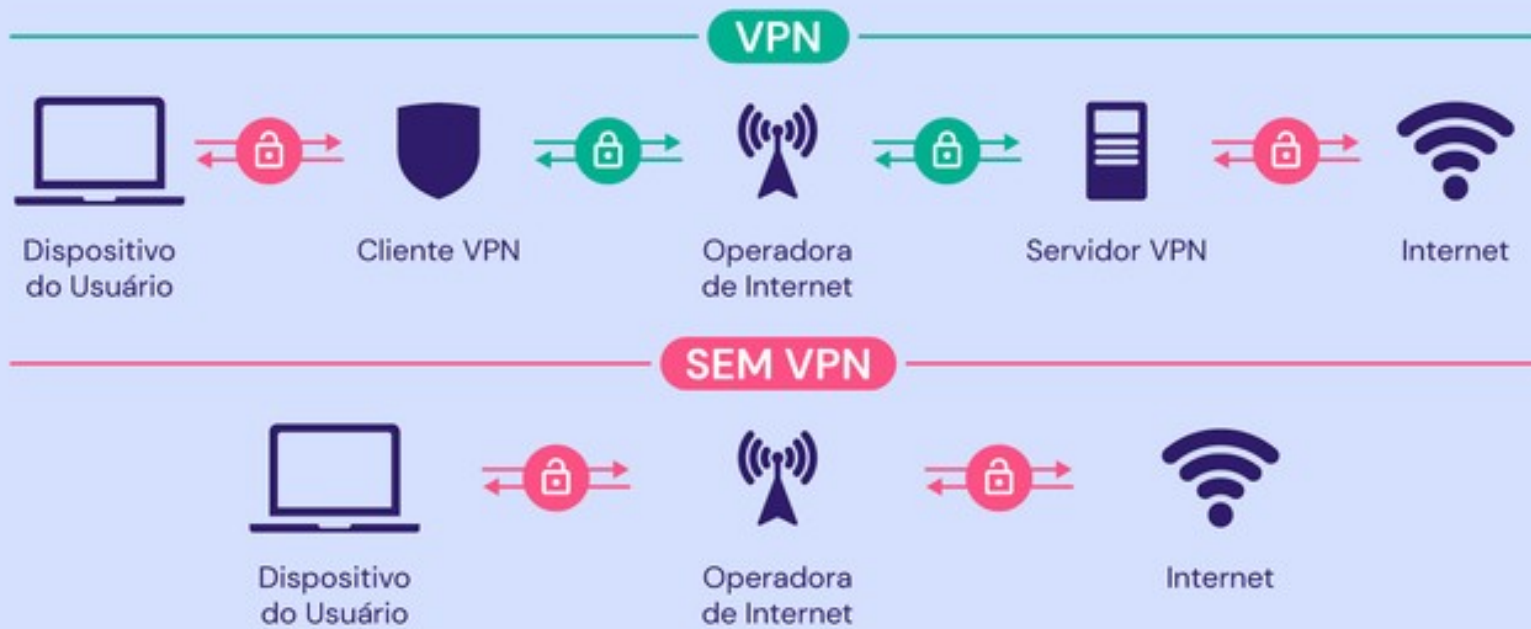


VPN: Acesso à Internet



Três. Dois. Online

Como Funciona uma VPN





Fornecedores de VPN para acesso à Internet



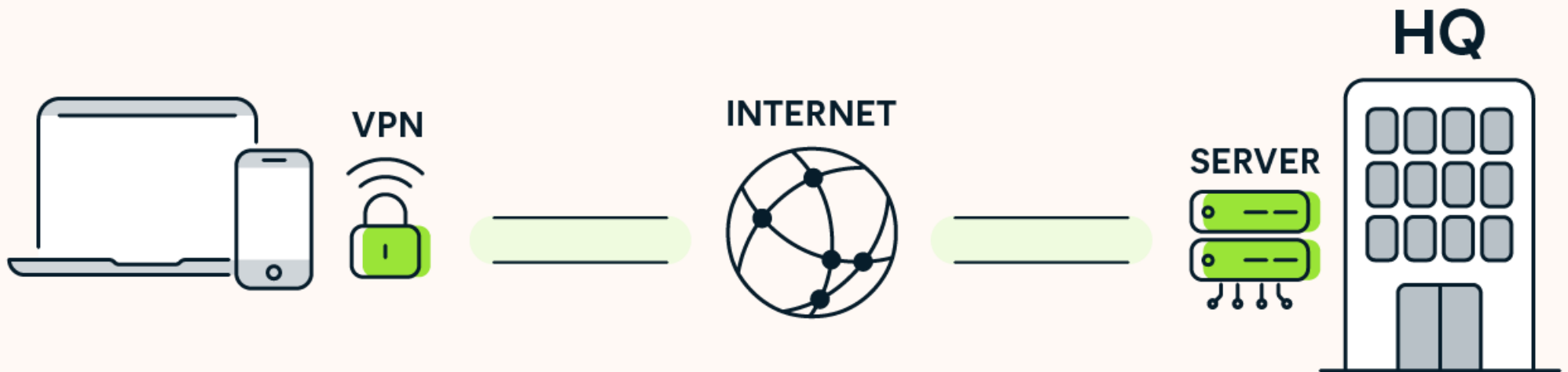


Rede Privada Virtual

- Rede privada virtual sobre uma rede insegura
 - Implementa um túnel cifrado que interliga dois extremos de confiança, através de um canal não seguro
 - Permite que utilizadores remotos acessem de forma segura à rede local
 - VPN dinâmica (dial VPN)
 - Permite estender uma rede, de forma segura, a locais geograficamente afastados
 - VPN estática (site-to-site VPN)



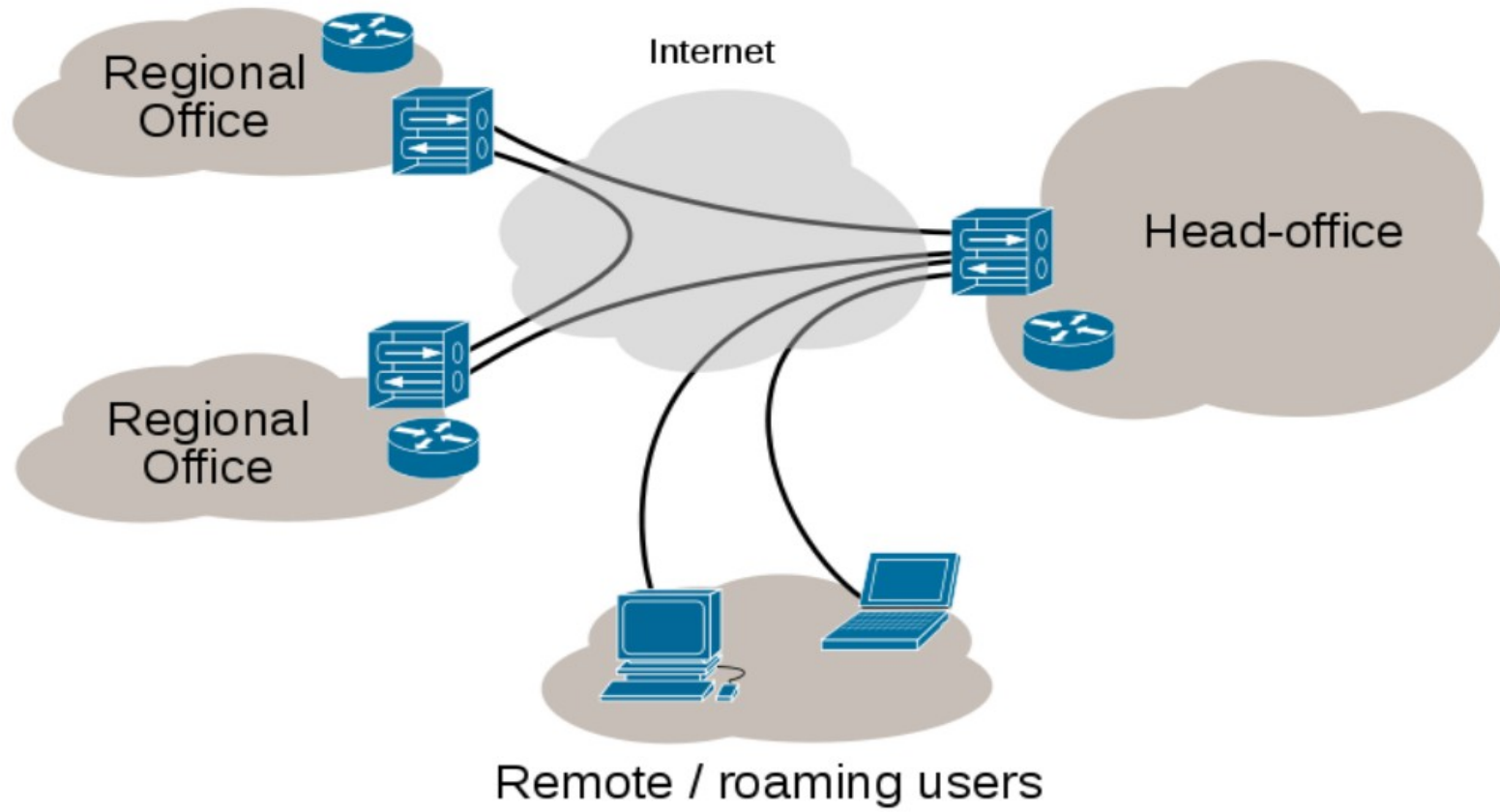
Interligação com utilizadores remotos





Tipos de VPNs

Internet VPN





Tecnologias

- Encapsulamento (Tunneling)
 - Envio dos pacotes originais encapsulados noutros pacotes, transmitidos pela rede pública, tornando opacos os pacotes originais.
 - Os pacotes originais podem ser dos mais diversos protocolos
- Autenticação
 - Para a verificação da identidade dos interlocutores e dos dispositivos envolvidos
 - Baseados em username e password: PAP, CHAP, RADIUS
 - Baseados em certificados de chave digitais de pública
- Mecanismos de Hashing
 - Para garantir a integridade das mensagens durante a travessia da rede pública
- Mecanismos de Cifra
 - Para garantir a confidencialidade da informação transmitida



Níveis de VPN e implementações

- VPNs de nível 2
 - PPTP, L2F e L2TP
- VPNs de nível 3
 - IPSec
- VPNs SSL
 - OpenVPN, Wireguard



Questões?

